

Aula 1 (Módulo 09) — O Pipeline de um SIEM

1. O que é um SIEM (visão simples)

Um **SIEM** (*Security Information and Event Management*) é o sistema central que recebe logs de **toda** a organização (Windows Event Logs, Sysmon, firewall, proxy, Linux syslog, aplicações...) e os transforma em algo **pesquisável e correlacionável** — é o que alimenta o workflow de SOC que vimos no Módulo 08. Sem SIEM, cada analista teria que logar em dezenas de sistemas diferentes, cada um com seu próprio formato de log, para investigar um único incidente.

2. O pipeline completo, etapa por etapa

Log gerado (Sysmon, firewall...)

↓

COLETA

↓

PARSING

↓

NORMALIZAÇÃO

↓

ENRIQUECIMENTO

↓

INDEXAÇÃO

↓

CORRELAÇÃO

↓

ALERTA

Coleta

O primeiro passo é **trazer o log até o SIEM**. Isso acontece através de **agentes** (um pequeno programa instalado no host, que lê os logs locais e os envia) ou **coleta sem agente** (o SIEM se conecta remotamente via syslog, API, ou outro protocolo para puxar os logs).

Por que importa para segurança: a cobertura de coleta é literalmente o que determina sua **visibilidade** — um host sem agente instalado é, na prática, um ponto cego. É comum, em auditorias de segurança, mapear "quantos % dos ativos críticos têm coleta de log ativa" como uma métrica fundamental.

Parsing

Um log bruto é só texto (lembra do Módulo 01, Aula 5, e do formato de linha syslog?). **Parsing** é o processo de **quebrar** essa linha de texto em campos estruturados — transformar:

```
Sep 19 14:32:07 servidor sshd[1234]: Failed password for root from 203.0.113.45 port 41522 ssh2
```

em algo como:

```
{ "timestamp": "2026-09-19T14:32:07", "host": "servidor", "processo": "sshd", "pid": 1234, "usuario": "root" }
```

Isso é exatamente o que fizemos "na mão" com regex no Módulo 06, Aula 2/3 — um SIEM faz isso automaticamente, para milhões de linhas, usando regras de parsing pré-configuradas para cada tipo de log conhecido.

Normalização

Fontes diferentes chamam o mesmo conceito de nomes diferentes: um firewall pode chamar de `src_ip`, um proxy de `client_address`, um Sysmon de `SourceIp`. **Normalização** mapeia tudo isso para um **esquema comum** (ex.: sempre `source.ip`), para que uma única busca funcione através de **todas** as fontes de dados ao mesmo tempo.

Por que importa: sem normalização, investigar "todas as conexões desse IP" exigiria escrever uma busca **diferente** para cada tipo de log — inviável em um ambiente com dezenas de fontes. Um esquema comum amplamente usado na indústria é o **OCSF** (*Open Cybersecurity Schema Framework* — mantido em código aberto, com apoio de várias empresas de segurança) e, historicamente, o **Common Event Format (CEF)**.

Enriquecimento

Depois de normalizado, o evento pode ser **enriquecido** com dados extras que não vieram no log original — por exemplo: "esse IP tem reputação ruim em alguma fonte de Threat Intelligence (Módulo 12)?", "esse hostname pertence a qual departamento, segundo o inventário de ativos?", "esse hash de arquivo é conhecido como malicioso?".

Por que importa: enriquecimento é o que transforma "203.0.113.45 tentou logar" (fato neutro) em "203.0.113.45, que já apareceu em 3 feeds de threat intel como servidor de C2, tentou logar" (contexto acionável) — muda completamente a prioridade da triagem (Módulo 08).

Indexação

Depois de estruturado, o evento é **indexado** — guardado de um jeito que permite busca **rápida**, mesmo entre bilhões de eventos. É tecnicamente parecido com o índice de um livro: em vez de ler página por página, você vai direto onde o termo aparece. Ferramentas de SIEM usam motores de busca especializados por baixo dos panos (ex.: Elasticsearch, no caso do Elastic Stack).

Correlação

Correlação é onde a "inteligência" de detecção realmente acontece: regras que combinam **múltiplos eventos**, possivelmente de fontes diferentes, ao longo do tempo, para identificar um padrão que nenhum evento isolado revelaria. Lembra da regra Suricata do Módulo 04 ("5 tentativas de SSH em 60 segundos")? Isso é correlação — só que um SIEM correlaciona através de **muito mais** fontes: ex., "falha de login SSH seguida de sucesso, seguida de criação de tarefa agendada, seguida de conexão de saída para um IP desconhecido" — um único evento não conta essa história, mas a correlação sim.

Alerta

Quando uma regra de correlação (ou detecção baseada em anomalia — lembra do Módulo 04, Aula 1) dispara, o SIEM gera um **alerta**, que cai na fila do N1 — fechando o ciclo que já estudamos no Módulo 08.

3. Conectando tudo

Coleta	→ visibilidade (sem isso, ponto cego)
Parsing	→ texto bruto vira campos estruturados
Normalização	→ esquema comum entre fontes diferentes
Enriquecimento	→ contexto extra (threat intel, inventário)
Indexação	→ busca rápida em volume gigante
Correlação	→ padrões através de múltiplos eventos/fontes
Alerta	→ cai na fila do SOC (Módulo 08)

Cada etapa desse pipeline é, na prática, uma versão automatizada e em larga escala de algo que já fizemos manualmente em módulos anteriores — regex (Módulo 06), threshold de tentativas (Módulo 04), triagem (Módulo 08).

4. Exercício de reflexão

Pegue o `ssh-brute-force-parser` que construímos no Módulo 06, Aula 3, e mapeie cada parte do código para uma etapa deste pipeline:

1. Qual parte do script corresponde a "parsing"?
2. Qual parte corresponde a "correlação" (mesmo que simples — pense no `threshold`)?
3. O que falta no script para ele se comportar como "enriquecimento"? (Dica: pense em o que mais você poderia adicionar sobre cada IP.)

5. Recapitulando

- SIEM centraliza logs de toda a organização; sem coleta ampla, existem pontos cegos.
- Parsing extrai campos estruturados; normalização unifica o esquema entre fontes diferentes (ex.: OCSF, CEF).
- Enriquecimento adiciona contexto externo (threat intel, inventário); indexação permite busca rápida em volume gigante.
- Correlação combina múltiplos eventos/fontes para revelar padrões que nenhum evento isolado mostraria — é aqui que o alerta nasce.

Próxima aula (fecha o Módulo 09)

Laboratório prático — configurando um SIEM real (Wazuh) para receber logs, ver o pipeline funcionando de ponta a ponta.

Fontes recomendadas

- **NIST SP 800-92 — "Guide to Computer Security Log Management"**: referência oficial sobre gestão de logs, incluindo coleta e normalização. <https://csrc.nist.gov/pubs/sp/800/92/final>
- **OCSF (Open Cybersecurity Schema Framework) — documentação oficial**: esquema aberto de normalização usado por múltiplos fabricantes de segurança. <https://schema.ocsf.io/>

